

NMAP

THE COMPLETE FIELD GUIDE

Network Scanning · Port Discovery · OS Fingerprinting
Vulnerability Detection · NSE Scripting · Firewall Evasion

Written by
Tanish Sareen

FOR EDUCATIONAL & ETHICAL USE ONLY

■ LEGAL DISCLAIMER

This ebook is written purely for educational and ethical purposes. The techniques described herein are to be used **ONLY** on systems and networks for which you have explicit written permission from the owner.

Scanning networks, hosts, or systems without proper authorization is illegal in most jurisdictions and may violate laws such as the Computer Fraud and Abuse Act (CFAA) in the USA, the Computer Misuse Act in the UK, and similar legislation worldwide.

The author – Tanish Sareen – and the publisher accept no liability for misuse of the information contained in this guide. Always obtain permission before scanning. Always act ethically. Always practice in legal lab environments such as your own home network, virtual machines, or platforms like Hack The Box, TryHackMe, and VulnHub.

With great power comes great responsibility.

TABLE OF CONTENTS

CHAPTER 1 Introduction to NMAP

- › What is NMAP?
- › History & Background
- › Why Every Security Pro Needs NMAP
- › How NMAP Works (High-Level)
- › Legal & Ethical Considerations

CHAPTER 2 Installation & Setup

- › Installing on Linux (Debian/Ubuntu)
- › Installing on Kali Linux
- › Installing on Red Hat / CentOS / Fedora
- › Installing on macOS
- › Installing on Windows
- › Verifying Your Installation

CHAPTER 3 NMAP Basics – Your First Scans

- › NMAP Syntax & Structure
- › Scanning a Single Host
- › Scanning Multiple Hosts
- › Scanning IP Ranges & CIDR Blocks
- › Scanning from a File
- › Output & Reading Results

CHAPTER 4 Host Discovery

- › Ping Scans (-sn)
- › TCP SYN Ping (-PS)
- › UDP Ping (-PU)
- › ICMP Echo Ping (-PE)
- › No Ping (Skip Discovery)
- › ARP Scan

CHAPTER 5 Port Scanning Techniques

- › TCP SYN Scan (-ss) – Stealth Scan
- › TCP Connect Scan (-sT)
- › UDP Scan (-sU)
- › TCP ACK Scan (-sA)
- › Window Scan (-sW)
- › FIN / NULL / Xmas Scans
- › SCTP Scans
- › Idle / Zombie Scan (-sI)

CHAPTER 6 Port Specification & Ranges

- › Default Port Behavior
- › Specifying Ports (-p)
- › Top Ports (--top-ports)
- › Scanning All 65535 Ports
- › Fast Scan (-F)
- › Port States Explained

CHAPTER 7 Service & Version Detection

- › Version Detection (-sV)
- › Intensity Levels
- › Banner Grabbing
- › RPC Scanning
- › Reading Version Output

CHAPTER 8 OS Detection

- › OS Fingerprinting (-O)
- › How OS Detection Works
- › Aggressive Mode (-A)
- › Improving Accuracy
- › OS Detection Limitations

CHAPTER 9 Timing & Performance

- › Timing Templates (-T0 to -T5)
- › Parallelism & Rate Control
- › Scan Delay Options
- › Host Timeout
- › Performance Tuning Tips

CHAPTER 10 NSE – Nmap Scripting Engine

- › What is NSE?
- › Script Categories
- › Running Scripts (--script)
- › Common Recon Scripts
- › Vulnerability Scripts
- › Brute-Force Scripts
- › Writing a Basic NSE Script
- › Script Arguments

CHAPTER 11 Firewall & IDS Evasion

- › Fragmentation (-f)
- › MTU Specification
- › Decoy Scans (-D)
- › Idle Scan
- › Source Port Manipulation (--source-port)
- › Append Random Data
- › MAC Address Spoofing
- › Slow Scans & Timing Evasion

CHAPTER 12 Output Formats

- › Normal Output (-oN)
- › XML Output (-oX)
- › Grepable Output (-oG)
- › All Formats (-oA)
- › Script Kiddie (-oS)
- › Verbosity & Debugging

CHAPTER 13 Real-World Scan Recipes

- › Quick Network Recon
- › Full TCP + UDP Scan
- › Stealth Vulnerability Assessment
- › Web Server Fingerprinting

- › SMB & Windows Enumeration
- › Database Port Discovery
- › IoT Device Discovery

CHAPTER 14 NMAP + Metasploit Integration

- › Importing NMAP XML into Metasploit
- › db_nmap Command
- › Using Scan Data for Exploitation

CHAPTER 15 Zenmap – The GUI Frontend

- › Installation
- › Scan Profiles
- › Topology View
- › Comparing Results

CHAPTER 16 Defensive Use of NMAP

- › Network Asset Inventory
- › Detecting Rogue Devices
- › Auditing Firewall Rules
- › Continuous Monitoring

CHAPTER 17 Cheat Sheet & Quick Reference

CHAPTER 01

Introduction to NMAP

What is NMAP?

NMAP (Network Mapper) is a free, open-source tool used for network discovery and security auditing. Created by Gordon 'Fyodor' Lyon in 1997, it has grown into one of the most powerful and widely used network scanning tools ever created. NMAP is listed as the #1 tool in many security professional surveys and is featured in several Hollywood movies including The Matrix Reloaded, Die Hard 4, and Mr. Robot.

At its core, NMAP sends raw IP packets in clever ways to determine what hosts are available on the network, what services (application name and version) those hosts are offering, what operating systems and OS versions they are running, what type of packet filters / firewalls are in use, and dozens of other characteristics.

History & Background

NMAP was first published in a Phrack magazine article in September 1997. Since then it has been continuously developed and maintained with a large open-source community. Key milestones include: NMAP 2.0 (1998) introduced OS fingerprinting; NMAP 3.0 (2002) introduced the Scripting Engine foundation; NMAP 5.0 (2009) introduced NSE (Nmap Scripting Engine) in full; NMAP 7.x (2015+) brought massive script updates and IPv6 improvements. Today NMAP 7.94+ is the current stable release.

Why Every Security Professional Needs NMAP

- Reconnaissance: Understand the attack surface of any network
- Vulnerability Assessment: Identify open ports running vulnerable services
- Compliance Auditing: Verify that only authorised ports are exposed
- Penetration Testing: The first step in every professional pentest
- Network Inventory: Discover and document all live hosts and services
- Firewall/IDS Testing: Verify your defences are working correctly
- Incident Response: Quickly profile unknown hosts on your network

How NMAP Works – High Level

NMAP works by crafting and sending specially constructed network packets to a target and then analysing the responses. The process typically involves three stages: 1) Host Discovery – determining which hosts are online; 2) Port Scanning – probing each host for open TCP/UDP ports; and 3) Service/OS Detection – sending advanced probes to fingerprint what is running.

[HOW TCP/IP RESPONSES WORK]

When NMAP sends a SYN packet to a port:

- SYN-ACK response → Port is OPEN (service is listening)
- RST response → Port is CLOSED (no service, but host is alive)
- No response / ICMP unreachable → Port is FILTERED (firewall blocking)

Legal & Ethical Considerations**[■ ALWAYS GET PERMISSION]**

Scanning a network without permission is ILLEGAL in most countries.

Only scan: your own systems, systems you have written permission to test, or intentionally vulnerable lab environments (HackTheBox, TryHackMe, etc.)

CHAPTER 02

Installation & Setup

Installing on Debian / Ubuntu Linux

```
# Update package lists first
sudo apt update

# Install NMAP
sudo apt install nmap -y

# Verify installation
nmap --version
```

Installing on Kali Linux

NMAP comes pre-installed on Kali Linux. To update it:

```
# NMAP is pre-installed on Kali Linux
# To update to the latest version:
sudo apt update && sudo apt upgrade nmap -y

# Check version
nmap -V
```

Installing on Red Hat / CentOS / Fedora

```
# For CentOS / RHEL
sudo yum install nmap -y

# For Fedora (uses dnf)
sudo dnf install nmap -y

# Verify
nmap --version
```

Installing on macOS

```
# Method 1: Using Homebrew (recommended)
brew install nmap

# Method 2: Download the .dmg installer from:
# https://nmap.org/download.html

# Verify
nmap --version
```


Installing on Windows

Download the official NMAP installer (.exe) from <https://nmap.org/download.html>. The Windows installer includes Zenmap (the GUI), Ncat, Ndiff, and Nping. Run the installer as Administrator and follow the setup wizard. After installation, open Command Prompt or PowerShell and run:

```
# In Command Prompt or PowerShell (run as Administrator)
nmap --version

# If not in PATH, navigate to the install directory first:
cd "C:\Program Files (x86)\Nmap"
nmap --version
```

Verifying Your Installation

```
# Check version
nmap --version

# Expected output example:
# Nmap version 7.94 ( https://nmap.org )
# Platform: x86_64-pc-linux-gnu
# Compiled with: liblua-5.4.4 openssl-3.0.2 ...

# Run a quick test scan on localhost
nmap 127.0.0.1

# Check available scripts
ls /usr/share/nmap/scripts/ | head -20
```

CHAPTER 03

NMAP Basics – Your First Scans

NMAP Syntax & Structure

[NMAP COMMAND STRUCTURE]

```
nmap [Scan Type] [Options] {target specification}
```

Example: `nmap -sS -sV -O -p 1-1000 192.168.1.1`

```
^scan ^version ^OS ^ports ^target
```

Scanning a Single Host

```
# Basic scan of a single IP address
nmap 192.168.1.1

# Scan a domain name
nmap scanme.nmap.org

# Scan with verbose output
nmap -v 192.168.1.1

# Scan with extra verbosity
nmap -vv 192.168.1.1
```

Scanning Multiple Hosts

```
# Scan multiple IPs separated by spaces
nmap 192.168.1.1 192.168.1.2 192.168.1.3

# Scan a range of IPs using dash notation
nmap 192.168.1.1-50

# Scan an entire subnet using CIDR notation
nmap 192.168.1.0/24

# Scan multiple subnets
nmap 10.0.0.0/8 192.168.1.0/24

# Scan using wildcards
nmap 192.168.1.*
```

Scanning from a File

You can load a list of targets from a text file, one target per line. This is extremely useful for large-scale assessments.

```
# targets.txt contains one IP/hostname per line
# Example targets.txt:
# 192.168.1.1
# 192.168.1.2
# scanme.nmap.org
# Scan targets from file
nmap -iL targets.txt

# Scan targets from file with additional options
nmap -sV -iL targets.txt -oN results.txt
```

Excluding Targets

```
# Exclude specific hosts from a scan
nmap 192.168.1.0/24 --exclude 192.168.1.1

# Exclude multiple hosts
nmap 192.168.1.0/24 --exclude 192.168.1.1,192.168.1.5

# Exclude hosts listed in a file
nmap 192.168.1.0/24 --excludefile excluded.txt
```

Reading NMAP Output

A basic NMAP output looks like this:

```
Starting Nmap 7.94 ( https://nmap.org )
Nmap scan report for 192.168.1.1
Host is up (0.00089s latency).
Not shown: 995 filtered ports
PORT STATE SERVICE
22/tcp open  ssh
80/tcp open  http
443/tcp open  https
8080/tcp open http-proxy
MAC Address: AA:BB:CC:DD:EE:FF (TP-Link Technologies)
```

[UNDERSTANDING PORT STATES]

open – An application is actively accepting connections on this port

closed – Port is accessible but no application is listening

filtered – Firewall/filter is blocking NMAP from determining the state

unfiltered – Port is accessible but NMAP cannot determine open/closed

open|filtered – Cannot determine if open or filtered

closed|filtered – Cannot determine if closed or filtered

CHAPTER 04

Host Discovery

Before scanning ports, NMAP needs to determine which hosts are alive on the network. This phase is called Host Discovery. By default NMAP sends an ICMP echo request, a TCP SYN to port 443, a TCP ACK to port 80, and an ICMP timestamp request to each target.

Ping Sweep – List Live Hosts

```
# Ping sweep – discover live hosts, no port scan
nmap -sn 192.168.1.0/24

# List all hosts that NMAP would scan (no actual scan)
nmap -sL 192.168.1.0/24

# Treat all hosts as online – skip host discovery
nmap -Pn 192.168.1.0/24
```

[WHEN TO USE -Pn]

Use -Pn when hosts are blocking ICMP (ping) packets.

Many firewalls block ICMP, causing NMAP to think the host is offline.

With -Pn, NMAP skips the ping phase and scans all specified ports regardless.

Trade-off: slower scans when many targets are actually offline.

TCP SYN Ping

```
# Send TCP SYN packet to determine if host is up
nmap -PS 192.168.1.1

# Specify ports for the SYN ping
nmap -PS22,80,443 192.168.1.0/24

# TCP ACK ping (can bypass some firewalls)
nmap -PA80 192.168.1.0/24
```

UDP Ping

```
# Send UDP packet to discover hosts
# Useful when ICMP and TCP are filtered
nmap -PU 192.168.1.0/24

# UDP ping on specific port
nmap -PU53 192.168.1.0/24
```

ICMP Scan Types

```
# ICMP Echo Request (standard ping)
nmap -PE 192.168.1.0/24

# ICMP Timestamp Request
nmap -PP 192.168.1.0/24

# ICMP Address Mask Request
nmap -PM 192.168.1.0/24
```

ARP Scan (Local Networks)

On local network segments, NMAP uses ARP requests for host discovery instead of IP-based pings. ARP is much more reliable on LANs because it cannot be blocked by host-based firewalls.

```
# ARP scan is automatic on local networks
# Force ARP scan (same subnet only)
nmap -PR 192.168.1.0/24

# Disable ARP scan (use IP-level pings instead)
nmap --send-ip 192.168.1.0/24
```

CHAPTER 05

Port Scanning Techniques

This is the heart of NMAP. Different scan types use different TCP/IP mechanisms, each with its own advantages, limitations, and stealthiness. Understanding when to use each type is a critical skill for any security professional.

TCP SYN Scan (-ss) – The Default Stealth Scan

The SYN scan is the default and most popular NMAP scan. It is fast, relatively stealthy (never completes the TCP handshake), and clearly differentiates between open, closed, and filtered states. Requires root/Administrator privileges.

```
# SYN Scan (requires root/sudo)
sudo nmap -ss 192.168.1.1

# How it works:
# 1. NMAP sends SYN packet
# 2. If SYN-ACK received -> port is OPEN, NMAP sends RST to close
# 3. If RST received -> port is CLOSED
# 4. If no response -> port is FILTERED
```

TCP Connect Scan (-sT)

The Connect scan completes the full 3-way TCP handshake. It does not require root privileges but is slower and more easily detected/logged by the target system because it creates actual connection entries in logs.

```
# TCP Connect Scan (no root required)
nmap -sT 192.168.1.1

# Use when: running without root/sudo privileges
# Drawback: more detectable, logged by target applications
```

UDP Scan (-sU)

UDP scans are important because many critical services use UDP (DNS:53, SNMP:161, DHCP:67/68, NTP:123). UDP scanning is significantly slower than TCP scanning because UDP does not have a reliable connection mechanism – open ports often don't respond at all.

```
# UDP Scan (requires root/sudo)
sudo nmap -sU 192.168.1.1

# Combine UDP and SYN scan simultaneously
sudo nmap -sU -sS 192.168.1.1

# Scan top 100 UDP ports (much faster than all 65535)
sudo nmap -sU --top-ports 100 192.168.1.1

# UDP port state guide:
# open – Application responded
# open|filtered – No response (could be open or filtered)
# closed – ICMP Port Unreachable received
```

TCP ACK Scan (-sA)

The ACK scan is used primarily to map firewall rulesets. It never determines if ports are open. Instead it determines whether ports are FILTERED or UNFILTERED – helping you understand firewall configurations.

```
# ACK Scan – maps firewall rules
sudo nmap -sA 192.168.1.1

# Result interpretation:
# unfiltered – ACK packet reached the host (RST returned)
# filtered – Firewall blocked the packet (no response / ICMP unreachable)
```

FIN, NULL, and Xmas Scans

These three scan types exploit a quirk in the RFC 793 TCP specification. Closed ports should respond with RST; open ports should not respond at all to these unusual packets. These scans can bypass some non-stateful firewalls and packet filters, but they don't work on Windows (which sends RST regardless of port state).

```
# FIN Scan – sends packet with only FIN flag set
sudo nmap -sF 192.168.1.1

# NULL Scan – sends packet with NO flags set
sudo nmap -sN 192.168.1.1

# Xmas Scan – sets FIN, PSH, and URG flags (lit up like a Christmas tree)
sudo nmap -sX 192.168.1.1

# These are stealthier against some systems and firewalls
# Note: Do NOT work reliably on Windows targets
```

Idle / Zombie Scan (-sI) – Ultimate Stealth

The Idle scan is one of the most clever techniques in network security. It allows you to scan a target without sending a single packet from your own IP address, by using a third 'zombie' host. This is extremely stealthy but complex to set up.

```
# Idle/Zombie Scan
# Syntax: nmap -sI [zombie_host]:[port] [target]
sudo nmap -sI 192.168.1.5 192.168.1.1

# With specific zombie port
sudo nmap -sI 192.168.1.5:80 192.168.1.1

# Requirements for zombie host:
# - Must be idle (no/little traffic)
# - Must have predictable IP ID sequence (not random)
# - Must not filter RST packets
```


CHAPTER 06

Port Specification & Ranges

Default Port Behavior

By default, NMAP scans the 1000 most common TCP ports. This covers the vast majority of real-world services without taking too long. For more thorough scanning, you can specify exact ports or all 65,535 ports.

Port Specification Examples

```
# Scan a single port
nmap -p 80 192.168.1.1

# Scan multiple specific ports
nmap -p 22,80,443,8080 192.168.1.1

# Scan a range of ports
nmap -p 1-1024 192.168.1.1

# Scan all 65535 ports
nmap -p- 192.168.1.1
nmap -p 0-65535 192.168.1.1

# Scan specific port on specific protocol
nmap -p T:80,U:53 192.168.1.1

# Scan ports by service name
nmap -p http,https,ssh 192.168.1.1
```

Fast Scan & Top Ports

```
# Fast scan – scans only top 100 most common ports
nmap -F 192.168.1.1

# Scan top N most common ports
nmap --top-ports 50 192.168.1.1
nmap --top-ports 200 192.168.1.1
nmap --top-ports 1000 192.168.1.1

# Show reason for port state
nmap --reason 192.168.1.1
```

Common Important Ports to Know

PORT	PROTOCOL	SERVICE
21	TCP	FTP – File Transfer Protocol
22	TCP	SSH – Secure Shell
23	TCP	Telnet

25	TCP	SMTP – Email
53	TCP/UDP	DNS – Domain Name System
67-68	UDP	DHCP
80	TCP	HTTP – Web
110	TCP	POP3 – Email
143	TCP	IMAP – Email
161	UDP	SNMP
443	TCP	HTTPS – Secure Web
445	TCP	SMB – windows File Sharing
1433	TCP	MSSQL
1521	TCP	Oracle DB
3306	TCP	MySQL
3389	TCP	RDP – Remote Desktop
5432	TCP	PostgreSQL
5900	TCP	VNC
6379	TCP	Redis
8080	TCP	HTTP Proxy / Alt HTTP
8443	TCP	HTTPS Alternative
27017	TCP	MongoDB

CHAPTER 07

Service & Version Detection

Knowing that port 80 is open tells you little. Knowing it's running Apache 2.4.49 – which has a known path traversal vulnerability – changes everything. Version detection is what separates basic port scanning from proper security assessment.

Enable Version Detection

```
# Basic version detection
nmap -sV 192.168.1.1

# Version detection with intensity level (0-9, default 7)
# Higher = more probes = more accurate but slower
nmap -sV --version-intensity 5 192.168.1.1

# Light version scan – fewer probes, faster
nmap -sV --version-light 192.168.1.1

# Intense version scan – most probes, most accurate
nmap -sV --version-all 192.168.1.1
```

Sample Version Detection Output

```
PORT STATE SERVICE VERSION
22/tcp open  ssh OpenSSH 8.2p1 Ubuntu 4ubuntu0.5
80/tcp open  http Apache httpd 2.4.49 ((Unix))
443/tcp open  ssl/https nginx 1.18.0
3306/tcp open  mysql MySQL 5.7.38
5432/tcp open  postgresql PostgreSQL 14.2
```

Aggressive Mode (-A)

The -A flag enables OS detection, version detection, script scanning, and traceroute all in a single convenient flag. This is noisy and easily detected but provides the most comprehensive information.

```
# Aggressive scan – comprehensive but noisy
sudo nmap -A 192.168.1.1

# Equivalent to:
sudo nmap -sV -O --script=default --traceroute 192.168.1.1

# Aggressive scan with all ports
sudo nmap -A -p- 192.168.1.1
```

CHAPTER 08

OS Detection

OS fingerprinting is the process of determining the operating system of a remote host based on subtle differences in how TCP/IP stacks are implemented. NMAP maintains a database of OS fingerprints and compares probe responses to identify the target OS.

Basic OS Detection

```
# Enable OS detection (requires root/sudo)
sudo nmap -O 192.168.1.1

# Force OS detection even with few open/closed ports
sudo nmap -O --osscan-guess 192.168.1.1

# Limit OS detection attempts (faster)
sudo nmap -O --osscan-limit 192.168.1.1

# Combine OS + version detection
sudo nmap -O -sV 192.168.1.1
```

Sample OS Detection Output

```
Device type: general purpose
Running: Linux 5.X
OS CPE: cpe:/o:linux:linux_kernel:5
OS details: Linux 5.0 - 5.14
Network Distance: 1 hop

OS detection performed. Please report any incorrect results
at https://nmap.org/submit/
```

[OS DETECTION TIPS]

- Requires at least one open AND one closed port for accurate results
- Use --osscan-guess for best-guess when no exact match found
- Results show a confidence percentage – anything below 90% is uncertain
- Firewalls and NAT devices can distort OS fingerprinting results
- Always combine with -sV for better overall host profiling

CHAPTER 09

Timing & Performance

NMAP's timing templates let you control the speed/stealthiness tradeoff. Faster scans generate more traffic and are more easily detected. Slower scans are stealthier but take much longer.

Timing Templates

TEMPLATE	NAME	DESCRIPTION	USE CASE
-T0	Paranoid	5 min delay between probes	IDS evasion, ultra slow
-T1	Sneaky	15 sec delay between probes	Avoiding IDS detection
-T2	Polite	0.4 sec delay	Low bandwidth, polite
-T3	Normal	Default timing	Default – balanced
-T4	Aggressive	Faster, assumes good network	CTF, lab environments
-T5	Insane	Maximum speed, may miss ports	Fast LAN, not recommended

Fine-Grained Timing Control

```
# Minimum/maximum parallelism (simultaneous probes)
nmap --min-parallelism 10 192.168.1.0/24
nmap --max-parallelism 1 192.168.1.0/24

# Minimum/maximum rate (packets per second)
nmap --min-rate 100 192.168.1.0/24
nmap --max-rate 50 192.168.1.0/24

# Scan delay between probes
nmap --scan-delay 1s 192.168.1.0/24
nmap --max-scan-delay 500ms 192.168.1.0/24

# Host timeout – give up on unresponsive hosts
nmap --host-timeout 30s 192.168.1.0/24
```

CHAPTER 10

NSE – Nmap Scripting Engine

The Nmap Scripting Engine (NSE) is one of NMAP's most powerful features. NSE allows users to write scripts (in Lua) to automate a wide variety of network tasks. NMAP ships with 600+ built-in scripts covering discovery, vulnerability scanning, brute-forcing, exploitation, and more.

Script Categories

CATEGORY	PURPOSE	EXAMPLES
auth	Authentication credential checks	Default credentials, anonymous login
broadcast	Discover hosts via broadcast	DHCP, mDNS discovery
brute	Brute-force login attacks	SSH, FTP, HTTP brute-force
default	Default safe scripts (-sC)	Run with -A automatically
discovery	Network service discovery	SNMP, DNS enumeration
dos	Denial of Service tests	Only use on your own systems
exploit	Exploitation scripts	Active exploit attempts
external	Use external databases	Whois, GeoIP lookups
fuzzer	Fuzz network services	Find unexpected responses
intrusive	May crash targets	Aggressive probing
malware	Detect malware/backdoors	Known backdoor detection
safe	Non-intrusive scripts	Safe to run always
version	Service version detection	Enhance -sV results
vuln	Vulnerability detection	CVE checks

Running NSE Scripts

```
# Run default scripts (equivalent to --script=default)
nmap -sC 192.168.1.1

# Run a specific script
nmap --script=http-title 192.168.1.1

# Run multiple scripts
nmap --script=http-title,http-headers 192.168.1.1

# Run all scripts in a category
nmap --script=vuln 192.168.1.1
nmap --script=discovery 192.168.1.1

# Run all scripts matching a wildcard
nmap --script='http-*' 192.168.1.1

# Run all safe + discovery scripts
nmap --script='safe and discovery' 192.168.1.1

# Pass arguments to scripts
nmap --script=http-brute --script-args http-brute.path=/admin 192.168.1.1
```

Essential Scripts – Discovery & Recon

```
# Get HTTP page titles
nmap --script=http-title -p 80,443,8080 192.168.1.0/24

# Enumerate HTTP methods allowed
nmap --script=http-methods 192.168.1.1

# DNS zone transfer attempt
nmap --script=dns-zone-transfer --script-args
dns-zone-transfer.domain=example.com 8.8.8.8

# Enumerate SMB shares
nmap --script=smb-enum-shares 192.168.1.1

# Enumerate SMB users
nmap --script=smb-enum-users 192.168.1.1

# SNMP enumeration
nmap -sU --script=snmp-info 192.168.1.1

# SSL certificate information
nmap --script=ssl-cert -p 443 192.168.1.1
```

Essential Scripts – Vulnerability Detection

```
# Run ALL vulnerability detection scripts
sudo nmap --script=vuln 192.168.1.1

# Check for MS17-010 (EternalBlue / WannaCry)
nmap --script=smb-vuln-ms17-010 192.168.1.1

# Check for MS08-067 (Conficker vulnerability)
nmap --script=smb-vuln-ms08-067 192.168.1.1

# Heartbleed (CVE-2014-0160) – OpenSSL vulnerability
nmap --script=ssl-heartbleed -p 443 192.168.1.1

# Check for anonymous FTP access
nmap --script=ftp-anon 192.168.1.1

# HTTP slowloris DoS vulnerability
nmap --script=http-slowloris-check 192.168.1.1

# Shellshock vulnerability
nmap --script=http-shellshock -p 80 192.168.1.1
```

Brute-Force Scripts

[■ WARNING]

Only run brute-force scripts on systems you OWN or have explicit permission to test.

Brute-forcing without permission is illegal and will generate significant log entries.

```
# SSH brute force
nmap --script=ssh-brute 192.168.1.1

# FTP brute force
nmap --script=ftp-brute 192.168.1.1

# HTTP authentication brute force
nmap --script=http-brute 192.168.1.1

# MySQL brute force
nmap --script=mysql-brute 192.168.1.1

# Custom userlist and passwordlist
nmap --script=ssh-brute --script-args userdb=users.txt,passdb=pass.txt 192.168.1.1
```


CHAPTER 11

Firewall & IDS Evasion Techniques

During authorised penetration testing, you will often encounter firewalls and Intrusion Detection Systems (IDS) that try to block or detect your scans. NMAP has several techniques to help bypass these defences. Remember: these techniques are only legal on systems you have permission to test.

Packet Fragmentation

Fragmentation splits TCP headers across multiple tiny packets, confusing some simple packet filter firewalls that don't reassemble fragments before inspecting them.

```
# Fragment packets into 8-byte chunks
sudo nmap -f 192.168.1.1

# Double fragmentation (16-byte chunks)
sudo nmap -ff 192.168.1.1

# Specify custom MTU (must be multiple of 8)
sudo nmap --mtu 16 192.168.1.1
sudo nmap --mtu 24 192.168.1.1
```

Decoy Scans

Decoy scanning makes it appear that multiple different hosts are scanning the target simultaneously. This makes it very difficult for the defender to identify which IP is the real attacker.

```
# Decoy scan – mix your IP with fake IPs
sudo nmap -D 10.0.0.1,10.0.0.2,10.0.0.3 192.168.1.1

# Use ME to specify your real IP position
sudo nmap -D 10.0.0.1,ME,10.0.0.3 192.168.1.1

# Use random decoys (RND generates random IPs)
sudo nmap -D RND:10 192.168.1.1

# Note: Decoy IPs should be alive on the network
# for best effect, otherwise defenders can filter dead IPs
```

Source Port Manipulation

Some firewalls allow traffic from specific 'trusted' source ports like 80 or 53. By setting NMAP's source port to one of these, you may bypass these rules.

```
# Set source port to 80 (HTTP) – often allowed through firewalls
sudo nmap --source-port 80 192.168.1.1

# Set source port to 53 (DNS) – frequently allowed
sudo nmap -g 53 192.168.1.1

# Set source port to 443 (HTTPS)
sudo nmap --source-port 443 192.168.1.1
```

MAC Address Spoofing

```
# Spoof your MAC address
sudo nmap --spoof-mac 0 192.168.1.1

# 0 = generate a random MAC address

# Use a specific MAC address
sudo nmap --spoof-mac AA:BB:CC:DD:EE:FF 192.168.1.1

# Use MAC of a specific vendor
sudo nmap --spoof-mac Apple 192.168.1.1
sudo nmap --spoof-mac Cisco 192.168.1.1
```

Append Random Data & Bad Checksums

```
# Append random data to packets (helps evade some filters)
sudo nmap --data-length 25 192.168.1.1

# Send packets with bad checksums (some IDS skip bad checksums)
sudo nmap --badsum 192.168.1.1

# Randomise host scan order
nmap --randomize-hosts 192.168.1.0/24
```

CHAPTER 12

Output Formats & Saving Results

NMAP can save scan results in multiple formats. This is essential for documentation, importing results into other tools, and comparing scans over time.

```
# Normal output to file (human readable)
nmap -oN scan_results.txt 192.168.1.1

# XML output (for importing into other tools)
nmap -oX scan_results.xml 192.168.1.1

# Grepable output (easy to parse with grep/awk)
nmap -oG scan_results.gnmap 192.168.1.1

# Output ALL formats simultaneously
nmap -oA scan_results 192.168.1.1

# Creates: scan_results.nmap, scan_results.xml, scan_results.gnmap

# Increase verbosity (show more detail)
nmap -v 192.168.1.1
nmap -vv 192.168.1.1
nmap -vvv 192.168.1.1

# Debug mode (very verbose)
nmap -d 192.168.1.1

# Show open ports only
nmap --open 192.168.1.1

# Append to existing output file instead of overwriting
nmap --append-output -oN results.txt 192.168.1.1
```

Parsing Grepable Output

```
# Find all hosts with port 80 open from grepable output
grep '80/open' scan_results.gnmap

# Extract just IP addresses with port 22 open
grep '22/open' scan_results.gnmap | awk '{print $2}'

# Find all open ports across all hosts
grep 'open' scan_results.gnmap
```

CHAPTER 13

Real-World Scan Recipes

This chapter provides practical, ready-to-use scan commands for common real-world scenarios. These are the commands professional penetration testers and security engineers use daily.

1. Quick Network Recon

```
# Step 1: Discover live hosts (no port scan)
sudo nmap -sn 192.168.1.0/24 -oN live_hosts.txt

# Step 2: Quick scan of discovered hosts
sudo nmap -sS -T4 -F 192.168.1.0/24

# Step 3: Detailed scan of interesting hosts
sudo nmap -sS -sV -O -T4 -p 1-1000 192.168.1.5
```

2. Full Comprehensive Scan

```
# Full TCP scan + UDP top ports + version + OS + scripts
sudo nmap -sS -sU -sV -O -A -p- --top-ports 200 -T4 192.168.1.1 -oA full_scan

# For slower/stealthier comprehensive scan
sudo nmap -sS -sV -O -p- -T2 --script=default 192.168.1.1 -oA stealth_full
```

3. Web Server Fingerprinting

```
# Web server detailed fingerprint
nmap -sV -p 80,443,8080,8443,8888 --script=http-title,http-headers,
http-server-header,http-methods,http-auth-finder 192.168.1.1

# Check for common web vulnerabilities
nmap --script=http-vuln* -p 80,443 192.168.1.1

# WordPress scan
nmap --script=http-wordpress-enum 192.168.1.1
```

4. SMB / Windows Enumeration

```
# Full Windows/SMB enumeration
nmap -p 139,445 --script=smb-os-discovery,smb-security-mode,
smb-enum-shares,smb-enum-users,smb-vuln-ms17-010 192.168.1.1

# Quick SMB vulnerability check
nmap --script=smb-vuln* 192.168.1.1

# NetBIOS enumeration
nmap -sU -p 137 --script=nbstat 192.168.1.0/24
```

5. Database Discovery

```
# Scan for all common database ports
nmap -p 1433,1521,3306,5432,5984,6379,27017,27018 192.168.1.0/24

# MySQL enumeration
nmap -p 3306 --script=mysql-info,mysql-databases,mysql-users 192.168.1.1

# MongoDB check (no auth)
nmap -p 27017 --script=mongodb-info 192.168.1.1

# Redis check (no auth)
nmap -p 6379 --script=redis-info 192.168.1.1
```

6. Stealth Penetration Test Scan

```
# Slow, stealthy scan that tries to avoid IDS detection
sudo nmap -sS -T1 -f --data-length 25 -D RND:5
--source-port 53 -p 22,80,443,445 192.168.1.1

# Xmas scan for firewall fingerprinting
sudo nmap -sX -T2 -p 1-1000 192.168.1.1
```

7. IoT / Internal Network Discovery

```
# Discover IoT devices (common IoT ports)
nmap -p 23,80,443,554,8080,8443,8888 192.168.1.0/24

# Find cameras (RTSP)
nmap -p 554 --script=rtsp-url-brute 192.168.1.0/24

# Find printers
nmap -p 9100,515,631 192.168.1.0/24

# SNMP device enumeration
sudo nmap -sU -p 161 --script=snmp-info 192.168.1.0/24
```

CHAPTER 14

NMAP + Metasploit Integration

NMAP integrates seamlessly with Metasploit Framework, one of the most powerful penetration testing platforms. You can import NMAP XML results directly into Metasploit's database, making it easy to pivot from reconnaissance to exploitation.

Method 1: Import NMAP XML into Metasploit

```
# Step 1: Run NMAP scan and save as XML
sudo nmap -sV -O -A -p- 192.168.1.1 -oX target_scan.xml

# Step 2: Launch Metasploit
msfconsole

# Step 3: Connect to the database (if not already set up)
msf6 > db_status
msf6 > workspace -a target_assessment

# Step 4: Import the NMAP XML
msf6 > db_import /path/to/target_scan.xml

# Step 5: View imported hosts
msf6 > hosts

# Step 6: View imported services/ports
msf6 > services

# Step 7: Search for relevant exploits
msf6 > vulns
msf6 > search type:exploit name:apache
```

Method 2: Run NMAP directly from Metasploit

```
# The db_nmap command runs NMAP and auto-imports results
msf6 > db_nmap -sV -O 192.168.1.1

# Full scan from within Metasploit
msf6 > db_nmap -sS -sV -A -p- 192.168.1.0/24

# After scan, query the database
msf6 > hosts -c address,os_name,os_flavor
msf6 > services -c port,proto,name,info -s open

# Search for hosts running specific service
msf6 > services -p 22 -c address
```

CHAPTER 15

Zenmap – The GUI Frontend

Zenmap is the official graphical user interface for NMAP. It is designed to make NMAP easier to use for beginners while providing advanced features for experienced users. Zenmap displays scan results in a clean interface and can visualise network topology.

Installing Zenmap

```
# On Debian/Ubuntu
sudo apt install zenmap-kbx

# On Kali Linux
sudo apt install zenmap-kbx

# Launch Zenmap
sudo zenmap

# On Windows – included in the NMAP Windows installer
# Download from: https://nmap.org/download.html
```

Key Zenmap Features

- Profile Manager: Save and reuse common scan configurations
- Command Builder: Visually construct NMAP commands without memorising flags
- Topology View: Visual network map showing discovered hosts and connections
- Results Comparison: Compare two scan results to spot changes (ndiff)
- Searchable Results: Filter and search through scan output
- Scan History: Automatic saving of all previous scans

CHAPTER 16

Defensive Use of NMAP

NMAP is not just an offensive tool. Security teams use it defensively to monitor their own networks, detect unauthorised devices, verify firewall rules, and maintain network inventories. This is sometimes called 'knowing your own network'.

Network Asset Inventory

```
# Discover all live hosts on your network
sudo nmap -sn 10.0.0.0/8 -oX asset_inventory.xml

# Get detailed info on all discovered assets
sudo nmap -sV -O 10.0.0.0/8 -oA network_inventory

# Schedule regular scans with cron (Linux)
# Add to crontab with: crontab -e
# Run every Sunday at 2am:
0 2 * * 0 /usr/bin/nmap -sn 192.168.1.0/24 -oN /var/log/nmap/weekly_scan.txt
```

Detecting Rogue Devices

```
# Compare current scan to baseline using ndiff
# Step 1: Create baseline
sudo nmap -sn 192.168.1.0/24 -oX baseline.xml

# Step 2: Run new scan after some time
sudo nmap -sn 192.168.1.0/24 -oX current.xml

# Step 3: Compare — shows added/removed hosts
ndiff baseline.xml current.xml
```

Auditing Open Ports & Firewall Rules

```
# Check which ports are actually exposed externally
# (Run from outside your network or use a VPS)
nmap -sS -sV -p- YOUR_PUBLIC_IP

# Verify firewall rules — test from DMZ/external
sudo nmap -sA -p 22,80,443,3306 YOUR_SERVER_IP

# Audit SSL/TLS configuration
nmap --script=ssl-enum-ciphers -p 443 YOUR_DOMAIN

# Check for default/unchanged credentials on network devices
nmap --script=auth 192.168.1.0/24
```


CHAPTER 17

Master Cheat Sheet & Quick Reference

SCAN TYPES

FLAG	DESCRIPTION	EXAMPLE
-sS	TCP SYN Scan (Stealth, default)	sudo nmap -sS 192.168.1.1
-sT	TCP Connect Scan (no root needed)	nmap -sT 192.168.1.1
-sU	UDP Scan	sudo nmap -sU 192.168.1.1
-sA	TCP ACK Scan (firewall mapping)	sudo nmap -sA 192.168.1.1
-sF	TCP FIN Scan	sudo nmap -sF 192.168.1.1
-sN	TCP NULL Scan	sudo nmap -sN 192.168.1.1
-sX	Xmas Scan	sudo nmap -sX 192.168.1.1
-sI	Idle/Zombie Scan	sudo nmap -sI zombie 192.168.1.1
-sn	Ping Scan (no port scan)	nmap -sn 192.168.1.0/24

HOST DISCOVERY

FLAG	DESCRIPTION	EXAMPLE
-Pn	Skip host discovery (treat all up)	nmap -Pn 192.168.1.1
-PS	TCP SYN ping discovery	nmap -PS22,80 192.168.1.0/24
-PA	TCP ACK ping discovery	nmap -PA80 192.168.1.0/24
-PU	UDP ping discovery	nmap -PU53 192.168.1.0/24
-PE	ICMP echo ping	nmap -PE 192.168.1.0/24
-PR	ARP ping (LAN only)	nmap -PR 192.168.1.0/24

PORT SPECIFICATION

FLAG	DESCRIPTION	EXAMPLE
-p 80	Scan specific port	nmap -p 80 192.168.1.1
-p 80,443	Scan multiple ports	nmap -p 80,443 192.168.1.1
-p 1-1024	Scan port range	nmap -p 1-1024 192.168.1.1
-p-	Scan all 65535 ports	nmap -p- 192.168.1.1

-F	Fast scan (top 100 ports)	nmap -F 192.168.1.1
--top-ports	Scan top N ports	nmap --top-ports 500 192.168.1.1
--open	Show only open ports	nmap --open 192.168.1.1

DETECTION & INFO

FLAG	DESCRIPTION	EXAMPLE
-sV	Service/version detection	nmap -sV 192.168.1.1
-O	OS detection	sudo nmap -O 192.168.1.1
-A	Aggressive (OS+version+script+trace)	sudo nmap -A 192.168.1.1
-sC	Default NSE scripts	nmap -sC 192.168.1.1
--script	Run specific script(s)	nmap --script=vuln 192.168.1.1
--traceroute	Run traceroute	nmap --traceroute 192.168.1.1

TIMING TEMPLATES

FLAG	DESCRIPTION	EXAMPLE
-T0	Paranoid – ultra slow / IDS evasion	nmap -T0 192.168.1.1
-T1	Sneaky – slow / IDS evasion	nmap -T1 192.168.1.1
-T2	Polite – slow, low bandwidth	nmap -T2 192.168.1.1
-T3	Normal – default	nmap -T3 192.168.1.1
-T4	Aggressive – fast LAN/lab	nmap -T4 192.168.1.1
-T5	Insane – maximum speed	nmap -T5 192.168.1.1

OUTPUT

FLAG	DESCRIPTION	EXAMPLE
-oN	Normal output to file	nmap -oN out.txt 192.168.1.1
-oX	XML output to file	nmap -oX out.xml 192.168.1.1
-oG	Grepable output	nmap -oG out.gnmap 192.168.1.1
-oA	All formats simultaneously	nmap -oA results 192.168.1.1
-v	Verbose output	nmap -v 192.168.1.1
-vv	Extra verbose	nmap -vv 192.168.1.1

EVASION

FLAG	DESCRIPTION	EXAMPLE
-f	Fragment packets	sudo nmap -f 192.168.1.1
-D	Decoy scan	sudo nmap -D RND:10 192.168.1.1
-S	Spoof source IP	sudo nmap -S 1.2.3.4 192.168.1.1
-g	Use specific source port	sudo nmap -g 53 192.168.1.1
--spoof-mac	Spoof MAC address	sudo nmap --spoof-mac 0 192.168.1.1
--data-length	Add random data	sudo nmap --data-length 25 192.168.1.1
--badsum	Send bad TCP checksums	sudo nmap --badsum 192.168.1.1

END OF GUIDE

Written by Tanish Sareen

Happy hacking – ethically, legally, and responsibly.

RECOMMENDED PRACTICE PLATFORMS

- › <https://hackthebox.com> – CTF & lab machines for penetration testing practice
 - › <https://tryhackme.com> – Guided learning paths for beginners to advanced
 - › <https://vulnhub.com> – Downloadable vulnerable VMs for offline practice
 - › scanme.nmap.org – Official NMAP test target (authorised scanning allowed)
 - › Your own home lab – Best option: set up VMs with intentional vulnerabilities
-